



Cybersecurity Basics

Penetration Testing 101

What is Penetration Testing?

In order for firms to understand their vulnerabilities from a cyber attacker's perspective, it is useful to undertake Penetration Testing (also known as "Pen Testing"). A Pen Test is an attack on a computer system that mimics a real-world cyber attack. Pen Tests can be targeted to access specific systems, or conducted on a more general basis to find vulnerabilities in a firm's systems in general. The NIST Framework, SANS Top 20 and OSFI Self-Assessment Guide all recommend that firms regularly conduct Pen Tests.

The main objective of penetration testing is to discover the weaknesses in a firm's cybersecurity. A Pen Test can also be used to test an organization's security policy compliance, its employees' security awareness and the organization's ability to identify and respond to security incidents.

Why conduct a Pen Test?

Penetration tests are valuable for several reasons¹:

1. Determining the feasibility of a particular set of attack vectors;
2. Identifying higher-risk vulnerabilities that result from a combination of lower-risk vulnerabilities exploited in a particular sequence;
3. Identifying vulnerabilities that may be difficult or impossible to detect with automated network or application vulnerability scanning software;
4. Assessing the magnitude of potential business and operational impacts of successful attacks;
5. Testing the ability of network defenders to successfully detect and respond to the attacks; and
6. Providing evidence to support increased investments in security personnel and technology.

Pen Tests can be an important tool in ensuring that appropriate resources are allocated to cybersecurity. The results of a Pen Test demonstrate clearly the vulnerabilities in a firm's security, and will provide

recommendations for remediation. The clear articulation of the actual risk and resources required to remediate it allow management to make a clear risk-based decision that is grounded in empirical evidence.

Types of Pen Tests

There are a variety of methods in which a Pen Test can be conducted. It can take the form of a white or glass box test (where all background and system information is provided) or a black box test (where only basic or no information is provided, except the company name).

White box testing simulates what might happen during an "inside job" or after a "leak" of sensitive information i.e. where the attacker has access to source code, network layouts, and possibly even certain passwords. In this form of internal security testing, assessors work from the internal network and assume the identity of a trusted insider or an attacker who has penetrated the perimeter defenses. White box testing also focuses on system-level security and configuration, including application and service configuration, authentication, access control, and system hardening.

Black box testing simulates an attack from someone who is unfamiliar with the system. This type of external security testing is conducted from outside the organization's security perimeter. It offers the ability to view the firm's security environment as it appears outside the security perimeter, usually as seen from the Internet, with the goal of revealing vulnerabilities that could be exploited by an external attacker.

There are also several variations in between, often known as grey box tests, where selected information is provided to the assessor.

The benefits of white vs. black vs. grey box testing will depend on the specific objective of the test.

In order to more accurately test the organization's cyber-readiness, firms may elect to undertake testing in a manner where only a small number of the firm's personnel are aware of the test. A secret test demonstrates how well the firm's monitoring and detection systems operate, and also tests the execution of the firm's incident response plan.

In conducting Pen Tests, firms must decide whether they test against production or non-production systems. Although testing against production systems is ideal from a security perspective (as it leaves no question as to whether production controls are consistent with an alternate testing environment) it may present risks to the firm's data. As such, it may be necessary to perform testing with the system offline and provide a facility for capturing the production state prior to the test and restoring after the test.ⁱⁱ

How to conduct a Pen Test

Pen tests can be automated with software applications or they can be performed manually. Either way, the process includes gathering information about the target before the test (reconnaissance), identifying possible entry points, attempting to break in (either virtually or in reality) and reporting back the findings.

The costs of Pen Testing can vary, depending on the type of test conducted and the amount of expertise a firm possesses. However, security assessment and deep testing don't necessarily require significant resources. Some very effective security tools are free and are commonly used by professional consultants, private industry and government security practitioners. A few of the commonly recommended tools include the following:

For scanning in the first steps of a security assessment or Pen Test, *Nmap* and *Nessus* are popular choices. Nmap is a simple, powerful and very well-reviewed scanner used by many security consultants. Nmap and its Zenmap graphical interface are free and available at nmap.org for virtually any platform from Vista and OS X to AmigaOS, and will run on low-power systems.

Nessus performs scans and up-to-date vulnerability testing in one interface through a purchased "feed" of vulnerability modules for the freely downloadable application. A free but delayed non-commercial "home feed" of updates will continue to be available at nessus.org after Tenable Inc. changes the Nessus license in July 2015.

The *Metasploit Framework* provides more operating system and application exploit information. Recently rewritten in Ruby with a graphical interface, it comes with several hundred common exploit modules in the basic download available at metasploit.com.

For testing Web applications specifically, the well-regarded *Nikto* has also undergone recent updates and it is available at cirt.net/nikto2.

Wireshark provides a network protocol capture and analysis, and its filtering and search functions are a solid non-invasive tool for beginners interested in TCP/IP. This tool is available for Windows, Linux and Mac. The "Buy" button at wireshark.org leads to a reminder that it's a free and open source.

KisMAC has a simple interface and a powerful wireless assessment and penetration testing features. This OS X application is available at trac.kismac-ng.org where one can also find an active support community.

In terms of Commercial Tools, [Pure Hacking](#), [Torrid Networks](#), [SecPoint](#), and [Veracode](#) should be considered, according to experts in the field.

Conduct regular external and internal penetration tests to identify vulnerabilities and attack vectors that can be used to exploit enterprise systems successfully. Penetration testing should occur from outside the network perimeter (i.e., the Internet or wireless frequencies around an organization) as well as from within its boundaries (i.e., on the internal network) to simulate both outsider and insider attacks. Quick win CSC 20-2 Any user or system accounts used to perform penetration testing, should be controlled

and monitored to make sure they are only being used for legitimate purposes, and are removed or restored to normal function after testing is over. Quick win CSC 20-3 Perform periodic Red Team exercises to test organizational readiness to identify and stop attacks or to respond quickly and effectively. Visibility/Attribution CSC 20-4 Include tests for the presence of unprotected system information and artifacts that would be useful to attackers, including network diagrams, configuration files, older penetration test reports, e-mails or documents containing passwords or other information critical to system operation. Visibility/Attribution CSC 20-5 Plan clear goals of the penetration test itself with blended attacks in mind, identifying the goal machine or target asset. Many APT-style attacks deploy multiple vectors--often social engineering combined with web or network exploitation. Red Team manual or automated testing that captures pivoted and multi-vector attacks offers a more realistic assessment of security posture and risk to critical assets. Visibility/Attribution CSC 20-6 Use vulnerability scanning and penetration testing tools in concert. The results of vulnerability scanning assessments should be used as a starting point to guide and focus penetration testing efforts. Configuration/Hygiene CSC 20-7 Devise a scoring method for determining the results of Red Team exercises so that results can be compared over time. Advanced CSC 20-8 Create a test bed that mimics a production environment for specific penetration tests and Red Team attacks against elements that are not typically tested in production, such as attacks against supervisory control and data acquisition and other control systems.

ⁱ Wikipedia

ⁱⁱ FINRA Report on Cybersecurity Practices - page 22